



Security Scan Report

insecure.democuda.org

2026-05-01 21:25:06

Executive Summary

Scan Details

2

High

5

Medium

16

Low

0

Info

Executive Summary

Scan Findings

Related Sites Discovery

[View Details →](#)

- Discovered 10 related subdomain(s), 4 responding to HTTP requests (44.4% response rate)
- 2 successful HTTP response(s) (200 OK) across all hosts
- Most common technologies: HSTS (1), PHP (1)

Organization Domain Discovery

[View Details →](#)

- Discovered 0 domain(s) potentially belonging to the same organization via passive sources.

Subfinder

[View Details →](#)

- No subdomains detected.

Katana

[View Details →](#)

- Detected 5 URLs.

External Script Detection

[View Details →](#)

- Website loads 1 external JavaScript files
- ⚠️ 1 scripts lack Subresource Integrity (SRI) protection

AI Chatbot Detection

[View Details →](#)

- No AI chatbot indicators were detected on the target website.

WhatWeb

[View Details →](#)

- Recommend running a scan on , which was the target redirection location from insecure.democuda.org

Wafw00f

[View Details →](#)

- No WAFs were detected.

Find The Admin Panel

[View Details →](#)

- Found 1 admin panel.

Test SSL

[View Details →](#)

- SSL/TLS scan identified 5 vulnerability issue(s) and 16 TLS 1.2+ cipher issue(s). Review recommended.

Identified Issues

- 23 potential issues were identified.
- Categories involved: Access Control, Encryption, WAF Detection.
- Severity breakdown: High=2, Medium=5, Low=16.

[View All Issues by Severity →](#)

WAF Impact Analysis

✓ **23**
ISSUES ADDRESSABLE BY WAF
23 of 23 (100.0%)

● **2**
HIGH SEVERITY (WAF)
Immediate protection available

⚡ **1-2**
DAYS TO DEPLOY WAF
vs 4-6 weeks for code fixes

⌚ **100.0%**
RISK REDUCTION
With immediate WAF deployment

Why Deploy a Web Application Firewall?



Immediate Protection

Deploy in 1-2 days versus weeks of development time for code-level fixes



Defense in Depth

Add an additional security layer while code updates are being developed and tested



Header Injection

Automatically inject missing security headers (CSP, HSTS, X-Frame-Options) without code changes



Traffic Intelligence

Monitor and analyze attack patterns to identify threats before they reach your application



Virtual Patching

Protect against known vulnerabilities while permanent fixes are being implemented



Reduced Time-to-Protection

Close security gaps in days instead of the weeks or months required for code refactoring

Recommended Approach: Deploy a WAF immediately to address 100.0% of identified issues, then implement code-level fixes as a second layer of defense for comprehensive, long-term security.

[↑ Home](#)

Issues Found

High Severity Issues

No WAF Detected WAF Detection

Reported by:

Wafw00f

[View tool details →](#)

Remediation: Deploy a WAF in front of the application to provide an additional layer of security against common web attacks.

Exposed Admin Panel Access Control

Reported by:

Find The Admin Panel

[View tool details →](#)

Remediation: Restrict access to admin panels using IP allowlisting, VPN requirements, or move to a non-public subdomain. Implement strong authentication, rate limiting, and monitor for unauthorized access attempts. A WAF can restrict access to admin panels using IP allow-listing and other access control policies to provide immediate protection.

[↑ Home](#)

Medium Severity Issues

BEAST (TLS 1.0 CBC ciphers) Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode ciphers under TLS 1.0 and migrate the supported minimum to TLS 1.2+. Modern AEAD cipher suites (GCM, ChaCha20-Poly1305) are not vulnerable. A WAF terminating TLS at the edge can enforce modern protocols regardless of origin configuration.

BEAST Vulnerability Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable TLS 1.0 (and SSL 3.0 if still enabled) and require TLS 1.2 or TLS 1.3. A WAF can enforce minimum TLS version at the edge without requiring origin server reconfiguration.

LUCKY13 Vulnerability Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites and prefer AEAD ciphers like AES-GCM or ChaCha20-Poly1305. Update TLS configuration to use only modern, secure cipher suites. A WAF can terminate TLS connections and disable weak CBC-mode cipher suites, providing immediate protection.

Weak Cipher: TLS_ECDHE_RSA_WITH_3DES_EDE_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable 3DES and all CBC-mode cipher suites. Use modern AEAD ciphers (AES-GCM, ChaCha20-Poly1305) with 128-bit or larger block sizes. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_3DES_EDE_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable 3DES, CBC-mode, and RSA key exchange cipher suites. Use ECDHE key exchange with modern AEAD ciphers for forward secrecy and strong encryption. A WAF can terminate TLS connections and disable this weak cipher suite.

[↑ Home](#)

Low Severity Issues

TLS_FALLBACK_SCSV Not Supported Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Enable TLS_FALLBACK_SCSV in the server's TLS stack (most modern TLS libraries support it; ensure the OpenSSL/BoringSSL/etc. version is recent and the configuration enables it). A WAF fronting the application typically supports SCSV out of the box.

SWEET32 Vulnerability Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable 64-bit block ciphers (3DES, Blowfish) and use only modern ciphers with 128-bit or larger block sizes (AES, ChaCha20). A WAF can terminate TLS connections and disable vulnerable 64-bit block ciphers.

Weak Cipher: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites in favor of AEAD ciphers. Configure the server to use only strong cipher suites like TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 or TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites in favor of AEAD ciphers. Configure the server to use only strong cipher suites like TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_ECDHE_RSA_WITH_CAMELLIA_256_CBC_SHA384 Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites and Camellia ciphers in favor of modern AEAD ciphers (AES-GCM, ChaCha20-Poly1305). A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_AES_256_CBC_SHA256 Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode and RSA key exchange cipher suites. Use ECDHE key exchange with AEAD ciphers for forward secrecy. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_AES_256_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode and RSA key exchange cipher suites. Use ECDHE key exchange with AEAD ciphers for forward secrecy. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_CAMELLIA_256_CBC_SHA256 Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode, Camellia, and RSA key exchange cipher suites. Use ECDHE key exchange with modern AEAD ciphers. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_CAMELLIA_256_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode, Camellia, and RSA key exchange cipher suites. Use ECDHE key exchange with modern AEAD ciphers. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256

Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites in favor of AEAD ciphers. Configure the server to use only strong cipher suites like TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 or TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA

Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites in favor of AEAD ciphers. Configure the server to use only strong cipher suites like TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_ECDHE_RSA_WITH_CAMELLIA_128_CBC_SHA256

Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode cipher suites and Camellia ciphers in favor of modern AEAD ciphers (AES-GCM, ChaCha20-Poly1305). A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_AES_128_CBC_SHA256

Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode and RSA key exchange cipher suites. Use ECDHE key exchange with AEAD ciphers for forward secrecy. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_AES_128_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode and RSA key exchange cipher suites. Use ECDHE key exchange with AEAD ciphers for forward secrecy. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_CAMELLIA_128_CBC_SHA256 Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode, Camellia, and RSA key exchange cipher suites. Use ECDHE key exchange with modern AEAD ciphers. A WAF can terminate TLS connections and disable this weak cipher suite.

Weak Cipher: TLS_RSA_WITH_CAMELLIA_128_CBC_SHA Encryption

Reported by:

Test SSL

[View tool details →](#)

Remediation: Disable CBC-mode, Camellia, and RSA key exchange cipher suites. Use ECDHE key exchange with modern AEAD ciphers. A WAF can terminate TLS connections and disable this weak cipher suite.

[↑ Home](#)

Detailed Results by Tool

This section provides detailed results from each security tool that was executed during the scan. Click on any tool name below to navigate directly to its results.

Related Sites Discovery

Discovers related subdomains and probes for live web services

Organization Domain Discovery

Discovers public-facing web domains belonging to the same organization

Subfinder

Subdomain finder.

Katana

Site crawler and URL finder.

External Script Detection

Detects and analyzes external JavaScript files loaded by the target.

AI Chatbot Detection

Detects indicators of agentic AI chatbots from passive scan data.

WhatWeb

Identifies technologies used by a website.

Wafw00f

Detects and identifies Web Application Firewalls (WAFs) on the target.

Find The Admin Panel

Scans target for exposed admin login pages

Test SSL

Tests SSL and TLS posture

[← Back to Tool Index](#)[↑ Home](#)[Next →](#)

Related Sites Discovery

Purpose: Discovers related subdomains and probes for live web services

Website: <https://github.com/mercutioviz/kast>

Timestamp: 2026-05-01T21:25:05.992+00:00

Summary:

Discovered 10 subdomain(s), 4 responding to HTTP requests (44.4% response rate)

Total Subdomains: 10

Live Hosts: 4 (44.4% response rate)

Dead Hosts: 5

Live Hosts (Top 25)

Host	Ports	Technologies
crapi.democuda.org	80	Port 80 (404): None Port 80 (404): None
insecure-js.democuda.org	80, 443	Port 443 (503): None Port 80 (503): None
secure-js.democuda.org	80, 443	Port 443 (503): None Port 80 (503): None
secure.democuda.org	80, 443	Port 443 (200): HSTS, PHP Port 80 (200): HSTS, PHP

Dead Hosts (5)

dvwa-secure.democuda.org, dvwa.democuda.org, test01.democuda.org, dvwa-insecure.democuda.org, lab.democuda.org

Details:

Target: insecure.democuda.org

Apex Domain: democuda.org

Scanned Domain: democuda.org

Total Subdomains Discovered: 10

Live Hosts: 4

Dead Hosts: 5

Response Rate: 44.4%

Unique Technologies: 2

Results:

[See live and dead host information below](#)

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

Organization Domain Discovery

Purpose: Discovers public-facing web domains belonging to the same organization

Timestamp: 2026-05-01T21:25:05.953+00:00

Summary:

No findings were produced by org_discovery.

Target: democuda.org | **Org:** Not detected

Details:

Organization: None

Apex domain: democuda.org

Domains discovered: 0

High confidence: 0

Sources: passive sources

Exposed services (Shodan): 0

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

Subfinder

Purpose: Subdomain finder.

Website: <https://github.com/projectdiscovery/subfinder>

Timestamp: 2026-05-01T21:25:05.973+00:00

Disposition: success

Summary:

No subdomains were found.

No subdomains found.

Details:

Detected 0 unique subdomain(s).

Results:

 [View subdomain details below](#)

Report Notes:

```
subfinder -d insecure.democuda.org -o docs/baseline-v3.0-phase-a/  
subfinder_tmp.json -cs -oJ
```

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

Katana

Purpose: Site crawler and URL finder.

Website: <https://github.com/projectdiscovery/katana>

Timestamp: 2026-05-01T21:25:06.022+00:00

Summary:

Detected 5 unique URL(s).

Discovered URLs (showing 5 of 5)

[GET] <https://insecure.democuda.org> [depth:0]

[header] [GET] <https://insecure.democuda.org/login.php> [depth:1]

[link] [GET] <https://insecure.democuda.org/dvwa/css/login.css> [depth:1]

[script] [GET] https://insecure.democuda.org/bnith__a5HB0grm1WEMmYR5qvW93nhCQMTstH86shiL01huWboUzrNkf81FRGDFA-ex9Uz8xSkzBzpKa1M= [depth:1]

[script] [GET] https://insecure.democuda.org/bnith__a5HB0grm1WFAI6HIaNYIcz1HB8KzE4YwctWeEXj6I9qlq9o00r3LpvBs4pe03NRHH7taYCY3NYY= [depth:2]

Details:

Detected 5 unique URL(s).

Results:

 [View URL details below](#)

Report Notes:

```
katana -silent -u insecure.democuda.org -o docs/baseline-v3.0-phase-a/katana.txt -ob
```

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

External Script Detection

Purpose: Detects and analyzes external JavaScript files loaded by the target.

Website: <https://developer.mozilla.org/en-US/docs/Web/HTML/Element/script>

Timestamp: 2026-05-01T21:25:05.962+00:00

Disposition: success

Summary:

Detected 1 external scripts: 0 cross-origin from 1 unique origins, 1 without SRI protection



External JavaScript Analysis

Total Scripts: 1

Cross-Origin: 0 from 1 origins

Without SRI: 1



<https://insecure.democuda.org> (1 scripts)



bnith_a5HB0grmlWEbxfQ97Zk6XqeP0O7ZqK82J5QBK1tCz2MBgpY9TgQupU2A9R0_HtkwkNLzS9hnaAE=

Details:

<https://insecure.democuda.org>: 1 scripts (1 without SRI)

Results:

```
{
  "target_url": "https://insecure.democuda.org"
  "target_origin": "https://insecure.democuda.org"
  "total_scripts": 1
  "total_scripts_found": 1
  "scripts_analyzed": 1
  "limited_by_config": false
  "same_origin_count": 1
  "cross_origin_count": 0
  "scripts_with_sri": 0
}
```

```
"scripts_without_sri": 1
"insecure_http_scripts": 0
"unique_origins":
[
  "https://insecure.democuda.org"
]
"unique_origin_count": 1
"scripts":
[
  {
    "url": [... truncated ...]
    "origin": [... truncated ...]
    "hostname": [... truncated ...]
    "path": [... truncated ...]
    "is_same_origin": [... truncated ...]
    "is_cross_origin": [... truncated ...]
    "has_sri": [... truncated ...]
    "integrity": null
    "crossorigin": null
    "is_https": [... truncated ...]
    "is_secure": [... truncated ...]
  }
]
"scripts_by_origin":
{
  "https://insecure.democuda.org":
  [
    [... truncated ...]
  ]
}
```

Report Notes:

Analyzed 1 external JavaScript files

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

AI Chatbot Detection

Purpose: Detects indicators of agentic AI chatbots from passive scan data.

Timestamp: 2026-05-01T21:25:06.028+00:00

Summary:

No AI chatbot indicators detected.

No AI chatbot indicators detected.

Details:

No AI chatbot indicators detected.

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

WhatWeb

Purpose: Identifies technologies used by a website.

Website: <https://github.com/urbanadventurer/whatweb>

Timestamp: 2026-05-01T21:25:05.987+00:00

Disposition: success

Summary:

{'http://insecure.democuda.org - HTTP 302': 'Cookies [PHPSESSID, security]; Country [UNITED STATES]; IP [4.152.87.222]; RedirectLocation [login.php]; X-Frame-Options [SAMEORIGIN]'}

{'http://insecure.democuda.org/login.php - HTTP 200': 'Cookies [PHPSESSID, security]; Country [UNITED STATES]; IP [4.152.87.222]; PasswordField [password]; Script [text/javascript]; Title [Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*]; X-Frame-Options [SAMEORIGIN]'}

Results:

```
{
  "name": "whatweb"
  "timestamp": "2026-05-01T21:25:05.984+00:00"
  "disposition": "success"
  "results":
    [
      {
        "target": [... truncated ...]
        "http_status": [... truncated ...]
        "request_config": [... truncated ...]
        "plugins": [... truncated ...]
      }
      {
        "target": [... truncated ...]
        "http_status": [... truncated ...]
        "request_config": [... truncated ...]
        "plugins": [... truncated ...]
      }
    ]
}
```

Report Notes:

```
whatweb -a 3 --read-timeout 30 --max-redirects 2 --log-json docs/baseline-  
v3.0-phase-a/whatweb.json insecure.democuda.org
```

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

Wafw00f

Purpose: Detects and identifies Web Application Firewalls (WAFs) on the target.

Website: <https://github.com/EnableSecurity/wafw00f>

Timestamp: 2026-05-01T21:25:05.981+00:00

Disposition: success

Summary:

No WAF detected

Details:

No WAF detected.

Test URL: /?

cisgshjh=%3Cscript%3Ealert%28%22XSS%22%29%3B%3C%2Fscript%3E&kbnwveul=UNION+SELECT+ALL+FROM+information_schema+AND+%22+or+SLEEP%285%29+or+%22&xxrtwudh=..%2F..%2Fetc%2Fpasswd

Test URL: /?jtxdihfp=%3Cscript%3Ealert%28%22XSS%22%29%3B%3C%2Fscript%3E

Test URL: /?hkhtifef=UNION+SELECT+ALL+FROM+information_schema+AND+%22+or+SLEEP%285%29+or+%22

Results:

```
[
  {
    "detected": false
    "firewall": "None"
    "manufacturer": "None"
    "trigger_url": null
    "url": "https://insecure.democuda.org"
  }
]
```

Report Notes:

```
wafw00f insecure.democuda.org -a -vvv -T 30 -f json -o docs/baseline-v3.0-  
phase-a/wafw00f.json
```

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)[Next →](#)

Find The Admin Panel

Purpose: Scans target for exposed admin login pages

Website: <https://github.com/DV64/Find-The-Admin-Panel>

Timestamp: 2026-05-01T21:25:05.999+00:00

Summary:

Found 1 exposed admin panel.

Exposed Admin Panels (showing 1 of 1)

Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development* - Confidence: 100.0%
<http://insecure.democuda.org/#admin/>

Details:

Exposed Admin Panels:

Panel #1:

URL: <http://insecure.democuda.org/#admin/>

Title: Login :: Damn Vulnerable Web Application (DVWA) v1.10 *Development*

Confidence: 100.0%

Status Code: 200

Login Form Detected: Yes

Technologies: Laravel, PHP

Results:

 [View panel details below](#)

Report Notes:

```
ftap --url insecure.democuda.org --detection-mode stealth -d docs/baseline-  
v3.0-phase-a -e json -f ftap.json
```

[← Back to Tool Index](#)[↑ Home](#)[← Previous](#)

Test SSL

Purpose: Tests SSL and TLS posture

Website: <https://testssl.sh/>

Timestamp: 2026-05-01T21:25:06.011+00:00

Summary:

Found 5 vulnerability issue(s) and 16 TLS 1.2+ cipher issue(s).

Details:

Vulnerabilities Found (5):

- fallback_SCSV
- SWEET32
- BEAST_CBC_TLS1
- BEAST
- LUCKY13

TLS 1.2+ Cipher Issues (16):

- cipher-tls1_2_xc028
- cipher-tls1_2_xc014
- cipher-tls1_2_xc077
- cipher-tls1_2_x3d
- cipher-tls1_2_x35
- cipher-tls1_2_xc0
- cipher-tls1_2_x84
- cipher-tls1_2_xc027
- cipher-tls1_2_xc013

- cipher-tls1_2_xc076
- cipher-tls1_2_x3c
- cipher-tls1_2_x2f
- cipher-tls1_2_xba
- cipher-tls1_2_x41
- cipher-tls1_2_xc012
- cipher-tls1_2_x0a

Results:

Scan completed. Found 21 issue(s). See details above.

Report Notes:

```
testssl -U -E --connect-timeout 10 --warnings=batch -oJ docs/baseline-v3.0-  
phase-a/testssl.json insecure.democuda.org
```

